전자서명법의 근본 문제

왜 한국만 사용자에게 개인키를 줬나

1999년 전자서명법의 핵심 논리:

```
한국 정부의 사고방식:
  "거래 당사자가 나중에 '내가 안 했다'고 부인하지 못하게 해야 한다"
  → "부인 방지에는 전자서명이 필요하다"
  → "전자서명에는 개인키가 필요하다"
  → "개인키를 사용자에게 줘야 한다"
  → 사용자가 USB/PC에 파일로 보관하고 직접 관리
```

한국 (1999년)

법이 특정 기술(PKI 인증서)을 유일한 전자서명 수단으로 지정
사용자가 개인키를 파일로 보관
분실, 유출, 갱신을 사용자가 책임

글로벌

"거래 부인 방지"는 서버측 로그 + 다중인증으로 해결
은행이 거래 기록을 보관하면 법적 효력 충분
사용자에게 개인키를 줄 이유가 없다

다른 나라는 "내가 안 했다"는 주장에 대해 서버 로그와 인증 기록으로 대응한다. 한국만 "사용자가 직접 전자서명을 했으니 부인할 수 없다"는 구조를 선택했다.

이론 vs 현실

개인키가 더 안전한 건 맞다. 하지만...

SSH에 쓰는 것과 같은 PKI 기술이다. 이론적으로 비밀번호보다 강력하다. 문제는 구현이다.

이론: 개인키의 장점

- 추측 불가능 (2048비트 랜덤)
- 피싱에 강함 (키 자체를 전송 안 함)
- 수학적으로 위조 불가능
- 부인 방지 (서명 사실을 부정 불가)

현실: 한국의 구현

- USB 메모리에 파일로 저장
- 파일 보호는 결국 비밀번호
- 파일 복사하면 누구나 사용 가능
- 개인키 + 비밀번호 = 비밀번호 수준

```
[한국의 선택]  비밀번호가 약하다 → 개인키가 강하다 → 사용자에게 개인키를 파일로 주자
               → 그 파일을 비밀번호로 보호 → 결국 비밀번호 수준으로 회귀

[글로벌의 선택]  비밀번호가 약하다 → 비밀번호 + 다른 요소를 합치자 (MFA)
               → 비밀번호 + OTP, 생체인증, 하드웨어 키
               → 나중에: 비밀번호 자체를 없애자 (FIDO2/패스키)
```

비유: "주차권이 비밀번호보다 안전하니까 국민에게 주차권을 나눠주자" → 주차권을 잃어버리니까 주차권에 비밀번호를 적어둠 → 결국 비밀번호가 뚫리면 주차권도 뚫림. 글로벌은 "번호판 인식으로 주차권 자체를 없애자"를 선택했다.

세대 비교

한국 주차장은 3세대, 한국 은행은 1세대

한국은 번호판 자동 인식 주차 시스템에서 세계를 리드한다. 같은 나라의 인터넷뱅킹은 1999년에 멈춰 있다.

세대	시기	한국 주차장	한국 금융 보안	글로벌 금융 보안
1세대	1990년대	물리 주차권	**공인인증서 (USB)**	비밀번호
2세대	2010년대	앱 주차권/전자 정산	**카카오/PASS 인증서**	비밀번호 + MFA
3세대	2020년대	**번호판 자동 인식**	아직 2세대에 멈춤	**FIDO2/패스키**

한국 금융 보안의 "혁신" (2020년)
공인인증서 → 카카오/PASS 인증서
물리 주차권 → 앱 주차권으로 바꾼 수준
여전히 "인증서"라는 매체를 나눠주는 구조

3세대: 매체가 없다
한국 주차장: 번호판만 있으면 됨
글로벌 금융: 지문/얼굴만 있으면 됨
잃어버릴 것 없음, 관리할 것 없음, 설치할 것 없음

한국은 주차장에서 이미 3세대를 구현했다. 같은 기술 철학을 은행에 적용하면 된다. **새로 발명할 것이 없다.**

핵심 개념

다른 나라에는 사용자 개인키가 없다

전 세계 표준 방식에서 일반 사용자에게 개인키를 발급하지 않는다.

```
[한국 공인인증서 모델]
  서버 개인키 → 서버가 관리 (HTTPS 암호화용)
  사용자 개인키 → 사용자가 관리  ← 한국만 이렇게 한다

[글로벌 표준 모델]
  서버 개인키 → 서버가 관리 (HTTPS 암호화용)
  사용자 인증 → 비밀번호 + MFA (개인키 없음)
```

계층	방식	누가 관리
통신 암호화	TLS (서버 인증서)	서버
본인 확인	ID/비밀번호	서버가 해시 저장
추가 인증	OTP, 생체인증	서버 + 사용자 기기
거래 보호	이상거래탐지(FDS)	서버
부인 방지	서버 로그 + 감사 추적	서버

패스키(FIDO2)는 개인키를 사용하지만, 기기의 보안 칩에 저장되어 사용자가 존재 자체를 모른다. 지문이나 얼굴로 자동 사용. 한국 공인인증서와 같은 "개인키"지만 사용자 경험은 정반대다.

2020년 이후

인증서 춘추전국시대

2020년 공인인증서 독점은 폐지됐다. 하지만 "인증서"라는 틀 자체는 유지됐다.

인증서	운영 주체	동기
카카오 인증서	카카오	4,700만 사용자 → 인증 시장 선점, 데이터 확보
네이버 인증서	네이버	카카오에 뺏기면 안 됨
PASS 인증서	SKT/KT/LGU+	본인인증(SMS) 시장 사수
토스 인증서	토스	금융 플랫폼 확장
KB모바일 인증서	국민은행	고객 이탈 방지
국민인증서	행정안전부	공공서비스용
공동인증서	금융결제원	기존 수익원 사수

결과: 사용자는 서비스마다 다른 인증서를 발급받아야 한다. 은행 갈 때 하나, 정부 민원 때 하나, 카카오 또 하나. 인증서가 1개에서 7개 이상으로 늘었을 뿐, 사용자의 부담은 오히려 증가했다.

근본 진단

주차권을 자꾸 잃어버리니까 더 많은 주차권을 만들었다

주차권을 잃어버리는 문제를 "더 다양한 주차권"으로 해결하려 했다. 주차권을 없앨 생각은 안 했다.

한국의 해결책: "더 다양한 주차권을 만들자"

앱 주차권 (카카오 인증서)
핸드폰 주차권 (PASS 인증서)
은행 전용 주차권 (KB모바일 인증서)
정부 전용 주차권 (국민인증서)
결과: 주차권이 1개에서 7개로 늘었다

글로벌의 해결책: "주차권을 없애자"

번호판 인식 → 자동 입출차
주차권이 없으니 잃어버릴 것도 없음
복사 불가, 관리 불필요
프로그램 설치: 0개

```
주차권을 줬더니 파생 산업이 통째로 생겼다:
  주차권 발급 (인증기관) → 주차권 보관함 (USB) → 주차권 관리 프로그램 (ActiveX)
  → 주차권 전달 프로그램 (Veraport) → 주차권 보호 프로그램 (TouchEn) → 주차권 분실 면책 (제9조)

주차권을 없애면 이 산업이 전부 사라진다. 그래서 아무도 바꾸고 싶어하지 않는다.
```

한국 주차장은 진작에 번호판 인식으로 바꿨다. 세계 금융도 바꿨다. 한국 은행만 아직도 주차권을 나눠주고 있다.

한국만의 구조

휴대폰 없으면 아무것도 할 수 없는 나라

한국은 모든 온라인 서비스에 휴대폰 본인인증을 요구한다. 미국은 이메일이면 충분하다.

상황	한국	미국
쇼핑몰 회원가입	휴대폰 본인인증 필수	이메일만 있으면 됨
게임 계정 생성	휴대폰 본인인증 필수	이메일만 있으면 됨
비밀번호 찾기	휴대폰 인증	이메일 링크
커뮤니티 댓글	휴대폰 인증 필수	익명 가능
은행 이체	휴대폰 인증 + 인증서	로그인 + 서버 FDS
휴대폰 없으면?	**아무것도 못 함**	이메일로 대체 가능

```
주민등록번호 수집 금지 (2014년)
  → 대체 수단 필요
  → 통신사가 "우리가 하겠다"
  → 통신사가 주민번호와 휴대폰 번호를 연결해 놨으니까
  → 휴대폰 인증 = 실명 확인
  → 통신사가 모든 온라인 서비스의 관문을 장악
```

미국에서 SSN을 웹사이트 회원가입에 입력하라고 하면 100% 사기다. 한국에서는 2014년까지 모든 웹사이트가 주민등록번호를 수집했다. 지금은 주민번호 대신 휴대폰 인증이 그 역할을 하고 있을 뿐이다.

여권의 비유

주민등록번호가 문제가 아니라 남용이 문제다

한국, 독일, 일본, 스웨덴 전부 국민 ID가 있다. 차이는 어디까지 요구하느냐다.

적절한 사용 (모든 나라)

은행 계좌 개설 (자금세탁 방지)
증권 거래 (내부자 거래 감시)
정부 민원 (세금, 복지)
통신사 후불 계약

한국만 요구하는 곳

온라인 쇼핑몰 회원가입 · 게임 계정 생성
커뮤니티/SNS 가입 · 배달 앱 가입
OTT 서비스 가입 · 와이파이 가입

```
비유: 주민등록번호 = 여권

다른 나라: 여권은 출입국과 은행에서만 보여준다.
한국: 편의점 들어갈 때도 여권을 보여줘야 한다.
      2014년에 "여권 직접 제시"는 금지됐지만,
      대신 "여권 번호를 아는 통신사가 대신 확인해줌"으로 바뀜.
      본질은 같다.
```

EU GDPR의 "데이터 최소화 원칙" — 서비스에 꼭 필요한 정보만 수집해야 한다. 쇼핑몰이 주민번호를 수집하면 불법이다. 한국은 정반대 방향으로 가고 있다.

종합

문제의 핵심: 보안의 책임을 사용자에게 떠넘기는 구조

지금까지 다룬 모든 문제를 관통하는 하나의 구조가 있다.

한국

영역	방법	책임
암호화	사용자 PC에 프로그램 설치	사용자
인증	사용자가 인증서(개인키) 관리	사용자
본인확인	사용자가 매번 증명	사용자
사고 시	"프로그램 안 깔았으니 네 잘못"	사용자

글로벌

영역	방법	책임
암호화	서버에서 TLS 처리	서비스 제공자
인증	서버가 MFA+FDS로 판단	서비스 제공자
본인확인	서버가 행동 패턴으로 판단	서비스 제공자
사고 시	"서버 보안 부족이면 은행 잘못"	서비스 제공자

```
뿌리 1: 국민 관리 사상 (1968~)
  주민등록제도 → 인터넷 실명제 → 휴대폰 본인인증

뿌리 2: 책임 회피 규제 (1999~)
  전자서명법 → 보안프로그램 의무화 → 면책 구조

뿌리 3: 규제가 만든 이권 (2005~)
  보안프로그램 업체 → 인증기관 → 통신사 본인인증
```

한국 IT 보안의 근본 문제는 기술이 아니라 철학이다. "보안의 책임이 누구에게 있는가"에 대해 한국은 사용자를, 세계는 서비스 제공자를 지목한다. 이 하나의 차이에서 인증서, 보안프로그램, 휴대폰 인증, 면책 구조가 전부 갈라진다.

AI 시대

AI 시대에 주차권을 나눠주는 나라

AI 에이전트가 사용자를 대신해 일하는 시대가 왔다. 한국의 인증 체계는 AI가 작동할 수 없는 구조다.

상황	글로벌	한국
"AI야, 잔고 확인해줘"	API 키 + OAuth → AI가 은행에 접근	보안프로그램 설치 팝업 → **AI 접근 불가**
"AI야, 결제해줘"	Stripe API → AI가 자동 결제	휴대폰 본인인증 → **사람만 가능**
"AI야, 서류 제출해줘"	정부 API → AI가 자동 처리	공동인증서 + 보안프로그램 → **AI 불가**
AI 보안 강화	서버측 AI FDS가 이상거래 실시간 판단	클라이언트 프로그램이 키보드 감시 → **AI 적용 불가**

```
주차장 비유로 보면:

[글로벌]  번호판 인식(3세대) → 자율주행차가 스스로 입출차 가능
          AI 에이전트가 API로 금융·결제·정부 서비스에 자동 접근

[한국]    물리 주차권(1세대) → 자율주행차가 주차권을 받을 수 없음
          AI 에이전트가 인증서 설치, 휴대폰 인증을 할 수 없음
          → 한국만 AI 경제에서 고립
```

클라이언트는 점점 다양해진다. PC → 맥 → 리눅스 → 스마트폰 → 태블릿 → AI 에이전트 → 로봇 → IoT. 클라이언트에 프로그램을 설치하는 방식은 새 기기가 나올 때마다 막힌다. 한국에서 맥으로 은행 업무가 힘든 이유, 리눅스로 불가능한 이유, AI 에이전트가 접근 못 하는 이유가 전부 같다. 앞으로 로봇이 심부름을 하는 시대가 오면? 로봇에 보안프로그램을 설치할 건가? **서버에서 처리하면 클라이언트가 뭐든 상관없다.**

결제 구조

왜 한국에는 KG이니시스가 필요한가

해외에서는 Stripe 하나로 모든 카드 결제가 된다. 한국에서는 PG사 → VAN사 → 카드사라는 다단계 구조가 필요하다.

해외 결제 구조

```
고객
 ↓
Stripe (PG) ———→ Visa/Mastercard
                        ↓
                  카드 발급 은행
```

중간 업체: 1개
수수료: 약 2.9%

한국 결제 구조

```
고객
 ↓
KG이니시스 (PG) → NICE (VAN) → 삼성카드
                               → 현대카드
                               → 하나카드
                               → ...각각 별도 연동
```

중간 업체: 2개 + 카드사별 개별 계약
수수료: 중첩 발생

왜 이런 구조가 생겼나: 한국 카드사들이 글로벌 표준 프로토콜(Visa/Mastercard 직접 연동)을 안 쓴다. 카드사마다 통신 방식이 달라서, 가맹점이 일일이 연동할 수 없다. 그래서 "중간에서 연결해줄게" → PG사(이니시스, KCP), "거래를 중계해줄게" → VAN사(NICE, KSNET)가 탄생했다. Stripe가 한국에 못 들어오는 이유이기도 하다.

글로벌 표준의 한국화

3D Secure도 한국에 오면 이렇게 된다

같은 3D Secure 프로토콜인데, 카드사가 응답하는 방식이 다르다. Mastercard는 "본인 확인해"라고만 한다. **어떻게** 확인하는지는 카드사가 결정한다.

항목	해외 카드 (Chase, Revolut 등)	한국 카드 (하나, 삼성 등)
인증 방식	이메일 코드, 은행 앱 푸시, 또는 자동 통과	**"앱카드를 설치해주세요"**
앱 없으면?	브라우저 팝업으로 대체 가능	**결제 불가**
자동 통과율	95% 이상 (AI 위험도 판단)	거의 없음 — 매번 인증
앱 구조	기존 은행 앱 하나로 통합	카드사마다 별도 앱카드 앱
최초 설정	없음 (은행 앱 이미 있음)	앱 설치 → 회원가입 → 본인인증 → 카드등록
소요 시간	3초	5~10분 (첫 결제 시)

같은 하나카드인데:

- 해외 사이트(Amazon)에서 쓸 때 → 3D Secure → 앱카드 설치 강요
- 다른 나라 카드(Chase)로 같은 사이트 결제 → 이메일 코드 한 번이면 끝
- 국내 사이트(쿠팡)에서 쓸 때 → 3D Secure 자체를 안 씀 → SMS + 비밀번호 앞 2자리

글로벌 표준을 도입해도, "사용자가 뭔가를 깔고 매번 증명해야 한다"는 한국의 철학이 적용되면 이렇게 된다. 번호판 인식 시스템을 설치해놓고 여전히 주차권을 나눠주는 구조다.

전환 경로

누가 무엇을 바꿔야 하는가

6개 이해관계자 각각의 핵심 과제를 한 눈에 보여주는 요약 테이블.

이해관계자	핵심 과제	시기
국회	전자금융거래법 제9조 면책구조 개정, 전자서명법에 FIDO2 인정	2027년
금융위원회	보안프로그램 설치 의무 폐지, 오픈API 의무화	2027년
은행/카드사	서버측 FDS 투자, 3D Secure 2.0 국내 적용, 패스키 도입	2027-2029년
PG사/VAN사	글로벌 결제 네트워크 직접 연동, PCI DSS 인증	2027-2028년
인터넷 서비스	휴대폰 본인인증 탈피, 이메일+MFA 전환	2027-2028년
통신사	본인인증 독점 해소, 수수료 투명화	2027-2028년

핵심 원칙: "뭘 깔아라"가 아니라 "뭘 달성해라". 기술을 지정하는 규제에서 목표를 지정하는 규제로 전환.

국회

국회: 법을 바꿔야 한다

상임위원회	법률	핵심 개정 내용	시기
정무위원회	전자금융거래법	제9조 면책구조 → 금융기관 책임 원칙 (EU PSD2 모델)	2027년
정무위원회	전자금융감독규정	제15조 보안프로그램 설치 의무 → 서버사이드 보안으로 대체	2027년
과방위	전자서명법	FIDO2/패스키를 법적 전자서명 수단으로 인정	2027년
과방위	정보통신망법	SMS OTP 단독 인증 금지 조항 신설	2028년
정무위	여신전문금융업법	VAN 수수료 투명화, 카드 네트워크 직접 연동 허용	2027년
행안위	주민등록법	온라인 본인확인 시 주민번호 전체 수집 금지	2028년

> 싱가포르는 2024년에 SMS OTP를 폐지했다. UAE는 2026년 3월, 인도는 4월, 필리핀은 6월에 폐지한다. 한국만 아직 논의조차 시작하지 않았다.

정부

정부: 규정을 바꿔야 한다

부처	핵심 과제	구체적 행동	시기
금융위원회	보안프로그램 폐지	전자금융감독규정 제15조 개정 → 서버사이드 FDS로 대체	2027 Q1
금융위원회	오픈API 의무화	은행의 오픈API 제공을 법적 의무로 격상	2028
금융감독원	PCI DSS 권고	대형 PG사·카드사에 PCI DSS 4.0.1 인증 의무화	2027-28
과기정통부	SMS OTP 폐지	싱가포르 MAS 벤치마킹, 단계적 폐지 로드맵 발표	2027 Q1
과기정통부	본인확인기관 확대	DID 기관, 핀테크 기업을 본인확인기관으로 추가 지정	2027
행정안전부	공공서비스 패스키	정부24, 홈택스에 패스키 로그인 필수 지원	2027 H2
개인정보보호위	ISMS-P 강화	인증 기준에 "피싱방지 인증(FIDO2) 지원" 항목 추가	2027.7

은행/카드사

은행과 카드사: 기술을 바꿔야 한다

과제	구체적 행동	해외 사례	시기
FDS 고도화	AI 기반 실시간 이상거래탐지. 클라이언트 의존도 연 10% 축소	영국 Barclays: AI FDS로 사기 탐지율 40% 향상	2026-28
패스키 도입	인터넷·모바일뱅킹에 패스키 필수 제공	싱가포르 DBS Bank: 2024년 패스키 전환	2026-28
3D Secure 2.0	국내 결제에도 3DS 2.0 정식 도입	일본: 2025년 전 가맹점 의무화	2027
보안프로그램 폐지	키보드보안·방화벽 등 단계적 폐지 (2027 옵션→2029 완전 폐지)	JP Morgan, HSBC: 설치 프로그램 0개	2027-29

> 이 기술들은 새로 발명할 것이 없다. TLS, FDS, FIDO2, 3D Secure — 전부 이미 검증된 글로벌 표준이다.

결제/인증 업체

PG사·VAN사·통신사: 구조를 바꿔야 한다

PG사/VAN사

- 글로벌 결제 네트워크(Visa/Mastercard) 직접 연동 추진
- PCI DSS 4.0.1 인증 의무 취득
- EMV 토큰화 도입 → 카드번호 유통 차단
- VAN사: 단순 중계 → 데이터 분석·AI 사기탐지로 전환

벤치마킹: 인도 UPI — 개방형 결제 인프라, 무료, 독점 방지

통신사

- 본인확인기관 추가 지정 수용 (DID, 핀테크)
- 건당 23~30원 수수료 투명화 및 인하
- PASS 인증 API 오픈API로 공개
- DID 기반 자기주권 인증으로 전환

벤치마킹: 에스토니아 e-ID — 통신사 의존 없는 국가 디지털 ID

타임라인

단계별 실행 로드맵

1년 차 — 2027년: 기반 조성

- 전자금융감독규정 보안프로그램 조항 개정
- 5대 시중은행 패스키 로그인 의무화
- SMS OTP 폐지 로드맵 발표
- PCI DSS 인증 공식 권고
- 본인확인기관 추가 지정

2년 차 — 2028년: 전환 가속

- SMS OTP 단독 인증 금지 (금융)
- 대형 PG사 PCI DSS 인증 의무화
- 오픈API 제공 의무화
- 공공서비스 패스키 필수 지원
- 주민번호 온라인 수집 최소화

5년 차 — 2030년: 체계 완성

- 클라이언트 보안프로그램 완전 폐지
- SMS OTP 완전 폐지
- 글로벌 PSP(Stripe 등) 정상 진입
- DID 인증 이용률 60%

핵심 지표

목표 지표 — 2030년까지

지표	현재 (2026년)	2028년 목표	2030년 목표
패스키 도입 금융기관	~10개	전 은행·증권사	전 금융기관
보안프로그램 설치 요구	~95%	50% 이하	0%
PCI DSS 인증 PG사	~10%	60% 이상	100%
SMS OTP 의존 서비스	~80%	30% 이하	0%
외국 PSP 한국 등록	0개	3개 이상	10개 이상
DID 인증 이용률	~5%	30%	60%

> 한국 주차장이 번호판 인식으로 전환하는 데 10년이 걸리지 않았다. 금융 보안도 마찬가지다. 기술은 이미 있다. 결정만 하면 된다.

1990년대 세계

인터넷 보안에 국제 표준이 생기다

1994년, 넷스케이프(Netscape)라는 회사가 웹 브라우저를 만들었다. 사람들이 처음으로 인터넷에서 물건을 사기 시작했다. 그런데 문제가 있었다 — **카드 번호를 입력하면 누군가 중간에서 훔쳐볼 수 있었다.**

그래서 넷스케이프가 **SSL**이라는 기술을 만들었다. SSL은 인터넷 통신을 암호화하는 기술이다. 쉽게 말하면, **편지를 봉투에 넣어서 보내는 것**이다. 중간에 누가 가로채도 봉투를 열 수 없다. 웹 브라우저 주소창에 자물쇠 모양이 뜨면 SSL(지금은 TLS로 발전)이 작동하고 있다는 뜻이다.

연도	사건	의미
1994	넷스케이프가 SSL 1.0 개발	인터넷 암호화의 시작 (보안 결함으로 비공개)
1995	SSL 2.0 공개	최초의 공개 암호화 통신. 아마존, 이베이가 전자상거래 시작
1999	TLS 1.0 발표	SSL의 후속 표준. 국제 표준으로 채택 (RFC 2246)

핵심: 보안을 브라우저와 서버 사이에서 처리했다. 사용자 PC에 별도 프로그램을 설치할 필요가 없었다. 이것이 이후 25년간 세계 보안의 기본 원칙이 된다.